Privacy note: Udyam Digital (prototype)

Team Sigmas, Airtel Sync 2026 Digital Track. Describes what the prototype does today. It uses synthetic data, mock registries and a mock payment step. No compliance certification is claimed.

WHAT WE COLLECT, WHY, AND WHAT WE KEEP

Data	Purpose	What we keep, and for how long in the prototype
Advisor answers: business type, staff, sites, city, pincode, monthly spend, GST yes/no, language, phone (WhatsApp)	Recommend a bundle and route to the right person	Stored with the session and lead so a person never has to ask again. No automatic expiry yet (see gaps).
Four documents: GST certificate, Udyam certificate, signatory ID, address proof; optional typed GSTIN	Verify the business for this order (KYC) and nothing else	**Images are deleted as soon as the check ends** (checked by an automated test). We keep the decision, the flags, and masked identifiers only (for example GSTIN `37••••••••6F1ZB`).
Consent record	Prove what the owner agreed to	Notice version, time, purpose, fields, language, and any withdrawal.
UPI ID (mock)	Autopay mandate demo	Stored masked (first character and bank handle). No money moves.

HOW CONSENT WORKS

- **Consent comes first.** The server refuses to read any document until consent is recorded; the refusal is logged.
- The notice is shown in English or Hindi before upload: purpose, what we read, what we keep, the AI boundary, and the right to withdraw.
- **Withdrawal is one click.** Processing stops, the KYC result and masked identifiers are removed from the order, the order is paused, and the withdrawal is logged. The owner can give consent again at any time.

THE AI BOUNDARY

The advisor is a scripted flow. An optional language model (off unless a key is set) may read the owner's **typed text answers only** (cut to 300 characters) to pick out business type, staff, city or spend. Its output is validated and discarded if invalid. **It never sees document images, full ID numbers or prices, and it never decides eligibility or price**: a rules engine does. Document reading (OCR, checksum, registry lookup) is a separate service from the advisor.

OTHER SAFEGUARDS IN THE PROTOTYPE

- Identifiers are masked in every screen, log and back-office view. Registry matching uses the registration number, never the name.
- Every consent, KYC result, deletion, hand-off and order event is written to an audit log, shown live to the owner in a "behind the scenes" panel.
- WhatsApp: documents are never collected there. A document sent on WhatsApp is refused and the owner is pointed to the secure page. Webhook signatures are verified when a secret is configured.
- A person is always reachable: unclear answers, no coverage, KYC review or "Talk to a person" hand the case over with the answers so far.

REGULATION (OUR UNDERSTANDING, NOT LEGAL ADVICE)

India's Digital Personal Data Protection Rules were notified on 13 November 2025. Consent-manager provisions apply from 13 November 2026 and most other duties from 13 May 2027. The design (purpose limitation, informed consent, easy withdrawal, minimal retention) is meant to fit this, but it has not been reviewed by a lawyer.

GAPS BEFORE REAL CUSTOMERS

- Retention schedule with automatic deletion; today leads and audit entries have no expiry.
- Encryption at rest, TLS, secrets management, and login with roles for the back office (it is open in the demo).
- Processor agreements and data-location review for any OCR or language-model vendor.
- Consent-manager integration, a named grievance contact, a breach-response process, and a data-subject access and erasure workflow.
- Independent security and privacy review.